

MARCO INTEGRATIVO GQM + PRAGMATIC

Aplicado al Sistema de Indicadores LINDDUN/LIINE4DU

Trazabilidad desde los Objetivos Nacionales hasta los Datos Técnicos

España 2025-2026 • Versión 1.0

"Medir sin objetivo es entretenimiento. Objetivo sin métrica es esperanza. La combinación de GQM y PRAGMATIC transforma ambas cosas en gestión."

PARTE I — FUNDAMENTOS METODOLÓGICOS

1.1 El Método GQM (Goal-Question-Metric)

El método GQM, desarrollado por Victor Basili y David Weiss en 1984 para la NASA/GSFC y posteriormente formalizado en el *Improvement Paradigm* de Basili, Caldiera y Rombach (1994), propone una estructura jerárquica de tres niveles para el diseño de sistemas de medición:

NIVEL 1 — OBJETIVO (Goal): Define qué se quiere medir, por qué, con qué propósito, desde qué perspectiva y en qué contexto. Los objetivos se formulan respondiendo a: *objeto de medición + propósito + foco de calidad + punto de vista + entorno*.

NIVEL 2 — PREGUNTA (Question): Caracteriza el objeto de medición. Cada objetivo genera una o más preguntas que deben responderse para determinar si el objetivo se está alcanzando. Las preguntas son interrogativas operativas, no normativas.

NIVEL 3 — MÉTRICA (Metric): Es la medida que responde a la pregunta. Puede ser objetiva (obtenida sin intervención humana directa) o subjetiva (requiere juicio). Para ser válida, la métrica debe: a) tener una fórmula precisa, b) especificar la fuente de datos, c) definir la frecuencia de medición, d) establecer el umbral de referencia.

1.2 La Metodología PRAGMATIC

PRAGMATIC (Brotby & Hinson, 2013) proporciona nueve criterios de calidad para evaluar cualquier métrica de seguridad/privacidad:

Criterio	Descripción	Pregunta clave
P — Predictivo	¿Anticipa problemas futuros?	¿Permite actuar antes de que ocurra el evento adverso?
R — Relevante	¿Es pertinente para decisiones reales?	¿Alguien cambiaría una decisión si el valor cambiara?
A — Accionable	¿Orienta a una acción concreta?	¿Qué hace exactamente el responsable si el valor supera el umbral?
G — Genuino	¿Mide lo que dice medir?	¿Es la métrica un proxy válido del fenómeno de interés?
M — Meaningful	¿Es comunicable a no técnicos?	¿El Consejo de Administración entiende lo que significa?
A — Accurate	¿Es técnicamente precisa?	¿Los datos son fiables, consistentes y reproducibles?
T — Timely	¿Está disponible cuando se necesita?	¿Se actualiza con la frecuencia necesaria para las decisiones?
I — Independiente	¿Es resistente a manipulación?	¿Puede el sujeto medido falsear el valor conscientemente?
C — Cheap	¿Es rentable su recogida?	¿El coste de medición es proporcional al valor que aporta?

Escala de puntuación: 0 (no cumple el criterio) a 10 (lo cumple perfectamente).

Umbrales: ≥ 8.0 Excelente ★★★★★ · ≥ 6.5 Buena ★★★★ · ≥ 5.0 Aceptable ★★★ · < 5.0 Revisar ✖

1.3 El Marco LINDDUN/LIINE4DU

LINDDUN es el framework de análisis de amenazas a la privacidad desarrollado por el grupo DistriNet de la KU Leuven (Wuyts et al., 2009–2025). El acrónimo original identifica siete categorías: *Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness, Non-compliance*. La versión más reciente, LINDDUN MAESTRO (2025), añade los indicadores *Inaccuracy* y *Exclusion*, resultando en la extensión LINDDUN+IE.

LIINE4DU es la adaptación española del marco desarrollada por la AEPD en octubre de 2024, que incorpora el contexto normativo español (RGPD + LOPDGDD) y adopta los nueve indicadores del marco extendido.

PARTE II — JERARQUÍA DE OBJETIVOS GQM

2.1 Nivel Estratégico — Objetivos Nacionales

Código	Objetivo Nacional	Contexto Regulatorio	Perspectiva
OBJ-ES-1	Demostrar cumplimiento continuo con el RGPD y la LOPDGDD	RGPD + LOPDGDD	DPO / Compliance
OBJ-ES-2	Garantizar la conformidad con el AI Act (obligaciones 2025–2026)	Reglamento (UE) 2024/1689	DPO + CTO / Riesgo IA
OBJ-ES-3	Cumplir las obligaciones de ciberseguridad bajo NIS2 y ENS	NIS2 + RD 311/2022 ENS	CISO / Operaciones
OBJ-ES-4	Proteger los derechos de los interesados de forma efectiva	RGPD Arts. 12–22	DPO / Transparencia
OBJ-ES-5	Gestionar el riesgo de privacidad en la cadena de valor	RGPD Art. 28; Arts. 44–49	DPO + Legal / Proveedores

2.2 Nivel Táctico — Objetivos por Indicador LINDDUN

OBJ-L (Linking): Cartografiar y controlar todos los flujos de datos que puedan generar perfiles individuales por combinación de fuentes.

- Perspectiva: DPO / Arquitecto de privacidad
- Foco: Minimización + Seudonimización + Privacidad por Diseño
- Norma principal: RGPD Arts. 5.1.c, 25, 30

OBJ-I (Identifying): Garantizar que los sistemas de la organización no permiten la identificación directa o indirecta de individuos más allá de lo estrictamente necesario.

- Perspectiva: DPO / CISO / Data Engineer
- Foco: Anonimización + Seudonimización + Control biométrico
- Norma principal: RGPD Arts. 4.1, 4.5, 9, 25; AI Act Arts. 5.1.d, 5.1.e

OBJ-NR (Non-repudiation): Asegurar la trazabilidad completa de accesos, modificaciones y supresiones de datos personales, garantizando que ninguna acción pueda negarse con posterioridad.

- Perspectiva: CISO / Auditoría interna / DPO
- Foco: Logs + No repudio + Gestión de derechos
- Norma principal: RGPD Arts. 5.2, 17, 32; eIDAS2

OBJ-D (Detecting): Controlar que los sistemas de observación (videovigilancia, monitorización laboral, IoT) respetan la proporcionalidad y la información previa al interesado.

- Perspectiva: DPO / CISO / RRHH
- Foco: Proporcionalidad + Información + EIPD
- Norma principal: RGPD Arts. 5.1.b, 5.1.c, 35; LOPDGDD Art. 22, 87

OBJ-DD (Data Disclosure): *Garantizar que ningún dato personal se divulga a terceros —sean encargados, IA generativa o receptores internacionales— sin base jurídica y garantías suficientes.*

- Perspectiva: DPO / Legal / CTO
- Foco: Encargados + IA gen. + Transferencias internacionales
- Norma principal: RGPD Arts. 5.1.b, 25.2, 28, 44–49; AI Act Arts. 10, 13, 53

OBJ-U (Unawareness): *Garantizar que los interesados están plenamente informados de todos los tratamientos y pueden ejercer sus derechos de forma efectiva.*

- Perspectiva: DPO / Comunicación / RRHH
- Foco: Transparencia + Consentimiento + ARCO+
- Norma principal: RGPD Arts. 5.1.a, 6, 7, 12–22; AI Act Arts. 4.2, 13

OBJ-NC (Non-compliance): *Mantener un sistema de gestión de cumplimiento robusto que minimice la exposición sancionatoria y garantice la capacidad de respuesta ante incidentes.*

- Perspectiva: DPO / CISO / Alta Dirección
- Foco: Gestión de brechas + EIPDs + AI Act readiness
- Norma principal: RGPD Arts. 24, 32–35; AI Act Arts. 5, 9, 17; NIS2 Art. 23

OBJ-IN (Inaccuracy): *Asegurar la exactitud de los datos en todo su ciclo de vida y detectar y corregir sesgos algorítmicos en sistemas de IA que puedan generar decisiones discriminatorias.*

- Perspectiva: DPO / Data Scientist / Auditoría de IA
- Foco: Exactitud + Sesgo + Equidad algorítmica
- Norma principal: RGPD Arts. 5.1.d, 16, 22; AI Act Arts. 9, 10, 15

OBJ-EX (Exclusion): *Eliminar barreras que impidan a colectivos vulnerables acceder a la información sobre sus datos personales y ejercer sus derechos.*

- Perspectiva: DPO / Accesibilidad / Dirección general
- Foco: Accesibilidad + Inclusión digital
- Norma principal: RGPD Art. 12; LOPDGDD; RD 1112/2018

PARTE III — CATÁLOGO COMPLETO DE MÉTRICAS GQM

Indicador L — LINKING (Vinculación)

L-M1: Porcentaje de Tratamientos con DFD Actualizado

- **Pregunta GQM:** Q-L-1 ¿Ha cartografiado la organización todos los flujos de datos con potencial de vinculación?
- **Fórmula:** $(L_{M1} = \frac{N_{\text{DFD_actualizados}}}{N_{\text{tratamientos_registrados_Art30}}} \times 100)$
- **Unidad:** %
- **Umbral:** $\geq 80\%$

- **Fuente:** Registro de actividades Art. 30
- **Frecuencia:** Anual o al producirse cambios sustanciales

L-M2: Quasi-Identificadores No Controlados

- **Pregunta GQM:** Q-L-1 (cont.) ¿Qué proporción de campos con potencial de re-identificación carece de controles?
- **Fórmula:** $(L_{M2}) = \frac{N_{\{QI_sin_control\}}}{N_{\{QI_total_catalogados\}}} \times 100$
- **Unidad:** %
- **Umbral:** $\leq 10\%$
- **Fuente:** Inventario de datos / Catálogo de atributos
- **Frecuencia:** Semestral

L-M3: ICAV — Índice de Controles Anti-Vinculación

- **Pregunta GQM:** Q-L-2 ¿Qué efectividad tienen los controles técnicos implementados para prevenir la vinculación no autorizada?
- **Fórmula:** $(ICAV = \frac{1}{N_{\{controles\}}} \sum_{i=1}^N \left(w_i \cdot \frac{C_i}{C_{i,max}} \right) \right)$
Donde (C_i) = nivel de implementación del control i (0–10) y (w_i) = peso del control i
- **Unidad:** Escala 0–10
- **Umbral:** ≥ 7.0
- **Fuente:** Auditoría técnica de controles
- **Frecuencia:** Semestral

L-M4: TTDL — Tiempo de Detección de Vinculación No Autorizada

- **Pregunta GQM:** Q-L-3 ¿Con qué rapidez detecta la organización intentos de vinculación no autorizados?
- **Fórmula:** $(TTDL = T_{\{detección\}} - T_{\{inicio_ataque\}})$ (en horas)
- **Unidad:** Horas
- **Umbral:** ≤ 72 horas
- **Fuente:** SIEM / Logs de seguridad
- **Frecuencia:** Continua / Mensual (promedio)

L-M5: % Modelos ML con EIPD de Linking

- **Pregunta GQM:** Q-L-4 ¿Se han evaluado formalmente los riesgos de vinculación en los modelos de ML antes de su despliegue?
- **Fórmula:** $(L_{M5}) = \frac{N_{\{modelos_ML_con_EIPD_linking\}}}{N_{\{modelos_ML_en_producción\}}} \times 100$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Registro de EIPDs / Catálogo de modelos ML
- **Frecuencia:** Continua (cada nuevo despliegue)

Indicador I — IDENTIFYING (Identificación)

I-M1: K-Anonimato Mínimo de Datasets Publicados

- **Pregunta GQM:** Q-I-1 ¿Garantizan los datasets publicados un nivel de anonimización verificable?
- **Fórmula:** $(k = \min_j |G_j|)$ donde (G_j) son los grupos de equivalencia del dataset
- **Unidad:** Entero $k \geq 1$
- **Umbral:** $k \geq 5$ (recomendado $gt29$); $k \geq 10$ (datos sensibles)
- **Fuente:** Herramienta de análisis de anonimización (ARX, sdcMicro)
- **Frecuencia:** Por cada publicación de dataset

I-M2: % Datasets con Análisis de Re-identificación Documentado

- **Pregunta GQM:** Q-I-1 (cont.) ¿Se documenta sistemáticamente el análisis de re-identificación antes de publicar datos?
- **Fórmula:** $(I_{\{M2\}} = \frac{N_{\{datasets_con_análisis\}}}{N_{\{datasets_publicados\}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Registro de publicaciones de datos
- **Frecuencia:** Semestral

I-M3: FAR — False Acceptance Rate en Sistemas Biométricos

- **Pregunta GQM:** Q-I-2 ¿Qué porcentaje de intentos de identificación biométrica incorrectos son aceptados erróneamente?
- **Fórmula:** $(FAR = \frac{FA}{FA + CR} \times 100)$ donde FA = falsas aceptaciones, CR = rechazos correctos
- **Unidad:** %
- **Umbral:** $\leq 0.01\%$
- **Fuente:** Sistema biométrico (logs de autenticación)
- **Frecuencia:** Mensual

I-M4: % Sistemas Biométricos con EIPD Válida y Actualizada

- **Pregunta GQM:** Q-I-3 ¿Tienen todos los sistemas de tratamiento biométrico una EIPD válida y actualizada?
- **Fórmula:** $(I_{\{M4\}} = \frac{N_{\{sistemas_biométricos_con_EIPD\}}}{N_{\{sistemas_biométricos_total\}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100% (sin excepciones)
- **Fuente:** Registro de EIPDs
- **Frecuencia:** Continua (cada nuevo sistema)
- **Nota:** Caso AENA 2025 (10,04 M€) es el caso de referencia de incumplimiento de esta métrica

I-M5: Epsilon (ϵ) de Privacidad Diferencial

- **Pregunta GQM:** Q-I-4 ¿Cuál es el nivel de riesgo residual de re-identificación en los modelos que usan privacidad diferencial?
- **Fórmula:** $(M(D) \approx_{(\epsilon, \delta)} M(D'))$ para cualquier par de datasets adyacentes D,

D'. En la práctica: ϵ representa el presupuesto de privacidad; se reporta el ϵ consumido vs. el ϵ máximo permitido.

- **Unidad:** Número real $\epsilon \geq 0$
- **Umbral:** $\epsilon \leq 8$ (moderado); $\epsilon \leq 1$ (fuerte)
- **Fuente:** Framework de ML (TensorFlow Privacy, OpenDP)
- **Frecuencia:** Por cada entrenamiento de modelo

Indicador NR — NON-REPUDIATION (No Repudio)

NR-M1: Completitud de Logs de Acceso a Datos Personales

- **Pregunta GQM:** Q-NR-1 ¿Se registran todos los accesos a datos personales de forma completa y tamper-proof?
- **Fórmula:** $(NR_{\{M1\}} = \frac{N_{\{\text{accesos_registrados}\}}}{N_{\{\text{accesos_totales_auditados}\}}} \times 100)$
- **Unidad:** %
- **Umbral:** $\geq 99.5\%$
- **Fuente:** SIEM / Sistema de logs
- **Frecuencia:** Mensual

NR-M2: Desviación entre Retención Real y Política de Logs

- **Pregunta GQM:** Q-NR-1 (cont.) ¿Se respetan los períodos de retención definidos en la política de logs?
- **Fórmula:** $(NR_{\{M2\}} = |T_{\{\text{retención_real}\}} - T_{\{\text{retención_política}\}}|)$ (en días)
- **Unidad:** Días de desviación
- **Umbral:** 0 días (tolerancia ± 7 días)
- **Fuente:** Sistema de gestión de logs
- **Frecuencia:** Trimestral

NR-M3: % Supresiones de IA Ejecutadas en ≤ 30 Días

- **Pregunta GQM:** Q-NR-2 ¿Se ejecuta efectivamente el derecho al olvido en los sistemas de IA dentro del plazo legal?
- **Fórmula:** $(NR_{\{M3\}} = \frac{N_{\{\text{supresiones_IA} \leq 30d\}}}{N_{\{\text{supresiones_IA_total}\}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Sistema de gestión de derechos / CRM del DPO
- **Frecuencia:** Mensual

NR-M4: TMRS — Tiempo Medio de Respuesta a Solicitudes de Supresión

- **Pregunta GQM:** Q-NR-2 (cont.) ¿Cuánto tarda la organización en dar respuesta efectiva a una solicitud de supresión?
- **Fórmula:** $(TMRS = \frac{1}{N} \sum_{i=1}^N (T_{\{\text{respuesta},i\}} - T_{\{\text{solicitud},i\}}))$ (en días)
- **Unidad:** Días
- **Umbral:** ≤ 30 días (plazo legal RGPD Art. 12.3)
- **Fuente:** CRM del DPO / Sistema de gestión de derechos
- **Frecuencia:** Mensual

NR-M5: % Consentimientos con Evidencia de No Repudio (Firma eIDAS)

- **Pregunta GQM:** Q-NR-3 ¿Pueden demostrarse los consentimientos ante la AEPD sin posibilidad de repudio posterior?

- **Fórmula:** $(NR_{M5} = \frac{N_{\text{consentimientos_con_firma_eIDAS}}}{N_{\text{consentimientos_totales_requeridos}}} \times 100)$

- **Unidad:** %

- **Umbral:** $\geq 80\%$ (para consentimientos de categorías especiales: 100%)

- **Fuente:** Plataforma de gestión de consentimientos

- **Frecuencia:** Semestral

Indicador D — DETECTING (Detección)

D-M1: IPV — Índice de Proporcionalidad en Videovigilancia

- **Pregunta GQM:** Q-D-1 ¿Son proporcionales los sistemas de videovigilancia instalados respecto al propósito declarado?

- **Fórmula:** $(IPV = \frac{1}{N_{\text{instalaciones}}} \sum_{i=1}^N \left(\frac{P_i + L_i + D_i}{3} \right))$
Donde P = proporcionalidad (0-10), L = legitimidad (0-10), D = documentación (0-10)

- **Unidad:** Escala 0-10

- **Umbral:** ≥ 8.0

- **Fuente:** Auditoría de instalaciones CCTV

- **Frecuencia:** Anual

D-M2: % Cámaras/Sistemas CCTV con EIPD Válida

- **Pregunta GQM:** Q-D-2 ¿Tienen todos los sistemas CCTV a gran escala su preceptiva EIPD?

- **Fórmula:** $(D_{M2} = \frac{N_{\text{CCTV_con_EIPD}}}{N_{\text{CCTV_que_requieren_EIPD}}} \times 100)$

- **Unidad:** %

- **Umbral:** 100%

- **Fuente:** Registro de EIPDs / Inventario de sistemas CCTV

- **Frecuencia:** Anual

D-M3: % Dispositivos IoT con Evaluación de Privacidad Documentada

- **Pregunta GQM:** Q-D-3 ¿Se evalúan los riesgos de privacidad de los dispositivos IoT antes de su despliegue?

- **Fórmula:** $(D_{M3} = \frac{N_{\text{IoT_con_eval_privacidad}}}{N_{\text{IoT_desplegados}}} \times 100)$

- **Unidad:** %

- **Umbral:** $\geq 90\%$

- **Fuente:** Inventario IoT / Registros de proyectos

- **Frecuencia:** Semestral

D-M4: Vulnerabilidades de Canal Lateral (side-channel) sin Remediar

- **Pregunta GQM:** Q-D-4 ¿Existen vulnerabilidades de canal lateral en sistemas IoT que puedan comprometer la privacidad?

- **Fórmula:** $(D_{M4} = N_{\text{vulns_side_channel_no_remediadas}})$ (número absoluto de vulnerabilidades conocidas y no corregidas)

- **Unidad:** Número entero
- **Umbral:** 0 (para vulnerabilidades críticas); ≤ 5 (para vulnerabilidades medias)
- **Fuente:** Gestión de vulnerabilidades / Pentesting
- **Frecuencia:** Mensual

D-M5: % Empleados con Acceso a Datos Formalmente Informados de Monitorización

- **Pregunta GQM:** Q-D-5 ¿Han sido informados todos los empleados monitorizados de la existencia y alcance de la monitorización?
- **Fórmula:** $(D_{\{M5\}} = \frac{N_{\{\text{empleados_informados_monit}\}}}{N_{\{\text{empleados_sujetos_monit}\}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Registros de RRHH / Acuses de recibo
- **Frecuencia:** Anual y al incorporar nuevos empleados

Indicador DD — DATA DISCLOSURE (Divulgación de Información)

DD-M1: % Encargados del Tratamiento con DPA Vigente y Auditado

- **Pregunta GQM:** Q-DD-1 ¿Tiene la organización contratos Art. 28 válidos con todos sus encargados del tratamiento?
- **Fórmula:** $(DD_{\{M1\}} = \frac{N_{\{\text{encargados_DPA_vigente_auditado}\}}}{N_{\{\text{encargados_total}\}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Registro de encargados / Contratos DPA
- **Frecuencia:** Semestral

DD-M2: % Transferencias Internacionales con Garantía Adecuada

- **Pregunta GQM:** Q-DD-2 ¿Tienen todas las transferencias de datos a terceros países una base jurídica válida (Arts. 44–49)?
- **Fórmula:** $(DD_{\{M2\}} = \frac{N_{\{\text{transf_con_garantía}\}}}{N_{\{\text{transf_internacionales_total}\}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Registro de actividades Art. 30 / Contratos internacionales
- **Frecuencia:** Semestral

DD-M3: % Prompts de IA Generativa con Datos Personales Detectados

- **Pregunta GQM:** Q-DD-3 ¿En qué proporción los usuarios introducen datos personales en herramientas de IA generativa?
- **Fórmula:** $(DD_{\{M3\}} = \frac{N_{\{\text{prompts_con_datos_personales}\}}}{N_{\{\text{prompts_total_auditados}\}}} \times 100)$
- **Unidad:** %
- **Umbral:** $\leq 2\%$

- **Fuente:** DLP (Data Loss Prevention) / Proxy de IA generativa
- **Frecuencia:** Mensual

DD-M4: % Herramientas de IA Generativa con EIPD Realizada

- **Pregunta GQM:** Q-DD-4 ¿Se ha evaluado el impacto en privacidad de todas las herramientas de IA generativa en uso?
- **Fórmula:** $(DD_{M4} = \frac{N_{\text{herramientas_IAgen_con_EIPD}}}{N_{\text{herramientas_IAgen_total}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Inventario de herramientas IA / Registro de EIPDs
- **Frecuencia:** Continua (cada nueva herramienta aprobada)

DD-M5: IMD — Índice de Minimización de Datos

- **Pregunta GQM:** Q-DD-5 ¿Recopila la organización únicamente los datos estrictamente necesarios para cada finalidad?
- **Fórmula:** $(IMD = \frac{N_{\text{campos_justificados}}}{N_{\text{campos_recogidos_total}}} \times 100)$
- **Unidad:** %
- **Umbral:** $\geq 95\%$
- **Fuente:** Auditoría de formularios y APIs
- **Frecuencia:** Anual

Indicador U — UNAWARENESS (Desconocimiento)

U-M1: ILPP — Índice de Legibilidad de la Política de Privacidad

- **Pregunta GQM:** Q-U-1 ¿Están escritas las políticas de privacidad en un lenguaje comprensible para el ciudadano medio?
- **Fórmula** (Fernández Huerta, adaptación española de Flesch): $(ILPP = 206.84 - 0.60 \times \frac{N_{\text{sílabas}}}{N_{\text{palabras}}} - 1.02 \times \frac{N_{\text{palabras}}}{N_{\text{frases}}))$
- **Interpretación:** 0–29 Muy difícil · 30–49 Difícil · 50–59 Moderadamente difícil · 60–69 Normal · 70–79 Bastante fácil · 80–100 Fácil/Muy fácil
- **Umbral:** ≥ 60 (nivel "normal")
- **Unidad:** Puntos 0–100
- **Fuente:** Analizador de texto (online o Python NLTK)
- **Frecuencia:** Anual y en cada revisión de la política

U-M2: % Derechos ARCO+ Atendidos en el Plazo Legal (≤ 30 días)

- **Pregunta GQM:** Q-U-2 ¿Responde la organización a todos los derechos ARCO+ dentro del plazo legal?
- **Fórmula:** $(U_{M2} = \frac{N_{\text{solicitudes_resueltas_}\leq 30d}}{N_{\text{solicitudes_totales}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100% (Art. 12.3 RGPD no admite excepciones salvo prórroga justificada)
- **Fuente:** CRM del DPO / Sistema de gestión de derechos
- **Frecuencia:** Mensual

U-M3: % Consentimientos que Cumplen los 4 Requisitos del Art. 7 RGPD

- **Pregunta GQM:** Q-U-3 ¿Son jurídicamente válidos los consentimientos recabados?
- **Fórmula:** Los 4 requisitos son: (1) libre, (2) específico, (3) informado, (4) inequívoco. Una muestra auditada valora cada consentimiento (0 o 1 por requisito). $(U_{\{M3\}} = \frac{N_{\{\text{consentimientos_con_4_requisitos}\}}}{N_{\{\text{consentimientos_auditados}\}}} \times 100$)
- **Unidad:** %
- **Umbral:** 100%
- **Fuente:** Plataforma de gestión de consentimientos / Auditoría de muestra (mín. 10%)
- **Frecuencia:** Trimestral

U-M4: % Decisiones Automatizadas con Explicación Disponible

- **Pregunta GQM:** Q-U-4 ¿Se proporciona explicación suficiente a los afectados por decisiones automatizadas?
- **Fórmula:** $(U_{\{M4\}} = \frac{N_{\{\text{decisiones_auto_con_explicación}\}}}{N_{\{\text{decisiones_auto_total}\}}} \times 100$)
- **Unidad:** %
- **Umbral:** 100% (Art. 22 RGPD + Art. 13 AI Act)
- **Fuente:** Sistema de IA / Registro de decisiones automatizadas
- **Frecuencia:** Trimestral

U-M5: % Empleados con Acceso a Datos que han Recibido Formación en Privacidad

- **Pregunta GQM:** Q-U-5 ¿Está formado el personal con acceso a datos en sus obligaciones de privacidad?
- **Fórmula:** $(U_{\{M5\}} = \frac{N_{\{\text{empleados_acceso_datos_formados}\}}}{N_{\{\text{empleados_acceso_datos_total}\}}} \times 100$)
- **Unidad:** %
- **Umbral:** $\geq 90\%$ (Alta Dirección: 100% por AI Act Art. 4.2)
- **Fuente:** LMS / Registros de formación de RRHH
- **Frecuencia:** Anual

Indicador NC — NON-COMPLIANCE (Incumplimiento)

NC-M1: IMC — Índice de Madurez de Cumplimiento

- **Pregunta GQM:** Q-NC-1 ¿Qué solidez tiene el sistema de gestión de cumplimiento de la organización?
- **Fórmula:** Evaluación multicriterio de los componentes del sistema de gestión: $(IMC = \frac{1}{\sum_{k=1}^7 C_k})$ donde los 7 componentes son: Política (C1), DPO (C2), Registro actividades (C3), EIPDs (C4), Gestión brechas (C5), Derechos (C6), Formación (C7). Cada C_k se valora 0–10.
- **Unidad:** Escala 0–10
- **Umbral:** ≥ 7.0
- **Fuente:** Auditoría interna / Autodiagnóstico AEPD
- **Frecuencia:** Anual

NC-M2: % Tratamientos de Alto Riesgo con EIPD Válida y Actualizada

- **Pregunta GQM:** Q-NC-2 ¿Cumplen todos los tratamientos que requieren EIPD con esta obligación?
- **Fórmula:** $(NC_{\{M2\}} = \frac{N_{\{\text{tratamientos_alto_riesgo_con_EIPD_válida}\}}}{N_{\{\text{tratamientos_alto_riesgo_total}\}}}$)

$\{N_{\text{tratamientos_que_requieren_EIPD}}\} \times 100$

- **Unidad:** %
- **Umbral:** 100% (Art. 35 RGPD es una obligación sin margen discrecional)
- **Fuente:** Registro de actividades + Registro de EIPDs
- **Frecuencia:** Continua (cada nuevo tratamiento de alto riesgo)

NC-M3: Tasa de Brechas Notificadas a la AEPD en ≤ 72 Horas

- **Pregunta GQM:** Q-NC-3 ¿Notifica la organización todas las brechas relevantes a la AEPD dentro del plazo legal?
- **Fórmula:** $(NC_{\text{M3}} = \frac{N_{\text{brechas_notificadas_}\leq 72h}}{N_{\text{brechas_notificables_total}}} \times 100)$
- **Unidad:** %
- **Umbral:** 100% (Art. 33 RGPD no admite demoras injustificadas)
- **Fuente:** Registro de incidentes / Notificaciones AEPD
- **Frecuencia:** Continua / Mensual (revisión de media)

NC-M4: TMNB — Tiempo Medio de Notificación de Brechas

- **Pregunta GQM:** Q-NC-3 (cont.) ¿Con qué rapidez media notifica la organización las brechas detectadas?
- **Fórmula:** $(TMNB = \frac{1}{N} \sum_{i=1}^N (T_{\text{notificación},i} - T_{\text{conocimiento_brecha},i}))$ (en horas)
- **Unidad:** Horas
- **Umbral:** ≤ 48 horas (margen de seguridad de 24h sobre el límite legal de 72h)
- **Fuente:** Sistema de gestión de incidentes
- **Frecuencia:** Por evento; media mensual

NC-M5: IPAA — Índice de Preparación para el AI Act

- **Pregunta GQM:** Q-NC-4 ¿Está la organización preparada para cumplir las obligaciones del AI Act según el calendario de implementación?
- **Fórmula:** Evaluación de 10 dimensiones del AI Act: $(IPAA = \frac{1}{10} \sum_{k=1}^{10} D_k)$ donde las dimensiones D1–D10 son: Inventario de sistemas IA (D1), Clasificación de riesgo (D2), Prohibiciones conocidas (D3), SGAI implementado (D4), Datos de entrenamiento (D5), Documentación técnica (D6), Transparencia usuarios (D7), Supervisión humana (D8), FRIA para alto riesgo (D9), Notificación autoridades (D10). Cada D_k se valora 0–10.
- **Unidad:** Escala 0–10
- **Umbral:** ≥ 6.0 (junio 2025); ≥ 8.0 (agosto 2026)
- **Fuente:** Autodiagnóstico AI Act / Auditoría de IA
- **Frecuencia:** Trimestral

Indicador IN — INACCURACY (Inexactitud)

IN-M1: Tasa de Registros con Mecanismo de Verificación de Exactitud

- **Pregunta GQM:** Q-IN-1 ¿Dispone la organización de mecanismos para verificar y mantener actualizada la exactitud de los datos?

- **Fórmula:** $(IN_{M1}) = \frac{N_{\text{registros_con_mecanismo_verificación}}}{N_{\text{registros_totales_activos}}} \times 100$
- **Unidad:** %
- **Umbral:** $\geq 85\%$
- **Fuente:** Auditoría de calidad del dato / Catálogo de datos
- **Frecuencia:** Anual

IN-M2: TMRR — Tiempo Medio de Resolución de Solicitudes de Rectificación

- **Pregunta GQM:** Q-IN-2 ¿Con qué eficiencia gestiona la organización las solicitudes de rectificación de datos inexactos?
- **Fórmula:** $(TMRR = \frac{1}{N} \sum_{i=1}^N (T_{\text{resolución},i} - T_{\text{solicitud},i}))$ (en días)
- **Unidad:** Días
- **Umbral:** ≤ 30 días (Art. 12.3 RGPD)
- **Fuente:** CRM del DPO / Sistema de gestión de derechos
- **Frecuencia:** Mensual

IN-M3: DIR — Disparate Impact Ratio

- **Pregunta GQM:** Q-IN-3 ¿Producen los modelos de IA de la organización resultados discriminatorios entre grupos protegidos?
- **Fórmula:** $(DIR = \frac{P(\hat{Y}=1 | A=1)}{P(\hat{Y}=1 | A=0)})$ donde A es la variable de grupo protegido (género, etnia, edad, discapacidad)
- **Interpretación:** $DIR < 0.80$ indica impacto adverso significativo (regla del 80% de la EEOC); $DIR > 1.25$ puede indicar preferencia injustificada al grupo protegido
- **Umbral:** $0.80 \leq DIR \leq 1.25$
- **Unidad:** Ratio $0-\infty$
- **Fuente:** Framework de evaluación de modelos ML (Fairlearn, AIF360)
- **Frecuencia:** Por cada entrenamiento o revisión periódica del modelo

IN-M4: % Modelos IA de Alto Riesgo con Auditoría de Sesgo Algorítmico

- **Pregunta GQM:** Q-IN-4 ¿Se auditan sistemáticamente los modelos de IA de alto riesgo para detectar sesgos discriminatorios?
- **Fórmula:** $(IN_{M4}) = \frac{N_{\text{modelos_alto_riesgo_con_auditoría_sesgo}}}{N_{\text{modelos_alto_riesgo_total}}} \times 100$
- **Unidad:** %
- **Umbral:** 100% (AI Act Art. 10 + Art. 43 para sistemas de alto riesgo)
- **Fuente:** Registro de auditorías de IA / Catálogo de modelos
- **Frecuencia:** Anual y en cada actualización significativa del modelo

Indicador EX — EXCLUSION (Exclusión)

EX-M1: Conformidad con WCAG 2.1 AA en Canales de Ejercicio de Derechos

- **Pregunta GQM:** Q-EX-1 ¿Son accesibles para personas con diversidad funcional los canales digitales para el ejercicio de derechos?
- **Fórmula:** $(EX_{M1}) = \frac{N_{\text{criterios_WCAG_conformes}}}{N_{\text{criterios_WCAG_aplicables}}} \times 100$

100) (escala de criterios WCAG 2.1 AA: 50 criterios)

- **Unidad:** %
- **Umbral:** $\geq 90\%$ (nivel AA pleno: 100%)
- **Fuente:** Auditoría de accesibilidad (herramienta WAVE, aXe, TAW)
- **Frecuencia:** Anual / Tras cada actualización web relevante

EX-M2: Número de Formatos Alternativos Disponibles para Información de Privacidad

- **Pregunta GQM:** Q-EX-2 ¿Proporciona la organización la información de privacidad en múltiples formatos accesibles?
- **Fórmula:** $(EX_{\{M2\}} = N_{\{\text{formatos_disponibles}\}})$ (ej.: texto, audio, vídeo con subtítulos, lectura fácil, braille bajo demanda)
- **Unidad:** Número de formatos
- **Umbral:** ≥ 3 formatos distintos
- **Fuente:** Auditoría de canales de comunicación
- **Frecuencia:** Anual

EX-M3: Disponibilidad de Canales No Digitales para el Ejercicio de Derechos

- **Pregunta GQM:** Q-EX-3 ¿Pueden los interesados sin competencia digital ejercer sus derechos sin necesidad de usar canales digitales?
- **Fórmula:** Evaluación binaria (1/0) de existencia de: (a) canal presencial, (b) canal postal, (c) teléfono de atención. Puntuación: 0–3.
- **Unidad:** Escala 0–3
- **Umbral:** ≥ 2 (mínimo canal presencial o postal + teléfono)
- **Fuente:** Auditoría de canales / Política de derechos
- **Frecuencia:** Anual

PARTE IV — CUADRO DE MANDO INTEGRADO (PRIVACY KPI DASHBOARD)

Tabla Resumen Ejecutivo

Indicador	Métricas	Top Métrica PRAGMATIC	IGM Contribución	Riesgo Regulatorio
L — Linking	L-M1 a L-M5	L-M3 ICAV (P=7.44)	10%	Alto
I — Identifying	I-M1 a I-M5	I-M3 FAR (P=8.33)	12%	Crítico
NR — Non-repudiation	NR-M1 a NR-M5	NR-M4 TMRS (P=8.44)	8%	Crítico
D — Detecting	D-M1 a D-M5	D-M5 Empleados (P=8.44)	8%	Crítico
DD — Data Disclosure	DD-M1 a DD-M5	DD-M1 DPAs (P=8.67)	15%	Crítico
U — Unawareness	U-M1 a U-M5	U-M3 Consentim. (P=8.00)	12%	Crítico
NC — Non-compliance	NC-M1 a NC-M5	NC-M3 Brechas (P=9.00)	15%	Crítico
IN — Inaccuracy	IN-M1 a IN-M4	IN-M3 DIR (P=7.67)	10%	Crítico
EX — Exclusion	EX-M1 a EX-M3	EX-M1 WCAG (P=7.56)	5%	Medio
Gobernanza	—	—	5%	Alto

Fórmula IGM Global

$$[\text{IGM} = \sum_{j \in \{L, I, NR, D, DD, U, NC, IN, EX, G\}} w_j \cdot \bar{M}_j]$$

Donde ($\bar{M}_j$) es la media ponderada de las métricas activas del indicador j, normalizadas en escala [0,1].

Umbral es IGM por nivel de madurez:

Nivel	IGM	Descripción
Inicial	0–39%	Sin sistema de gestión formal
Básico	40–54%	Cumplimiento mínimo declarativo
Definido	55–69%	Procesos documentados, inconsistente aplicación
Gestionado	70–84%	Métricas activas, mejora continua
Optimizado	85–100%	Excelencia en gestión de privacidad

Marco elaborado sobre las bases de Basili & Weiss (1984), Brotby & Hinson (2013), LINDDUN v2.0 / KU Leuven (2025), LIINE4DU 1.0 / AEPD (2024), EDPB Guidelines y el contexto regulatorio europeo-español vigente en abril de 2026. Versión 1.0.